

NEOLABS

SECURITY LABS | GREY-BOX PENTEST

Grey-Box Pentesting Foundations — Week 1

Weekly Learning Pack | Learn + Connect + Operate

Programme: NeoLabs x Renaissance Innovation Labs Cybersecurity Internship

Week 01

Version: 1.0

Classification: Student Training Material

Authorised synthetic training use only.

Purpose

Week 1 teaches the discipline that comes **before exploitation**: scope control, HTTP literacy, safe service discovery, application mapping, evidence collection and reproducible notes. Operation Night Watch is intentionally a normal-behaviour baseline.

1. What grey-box testing means

A grey-box tester receives limited authorised knowledge — for example a synthetic learner account, an assigned pod and a bounded target — but still verifies the application from a tester's perspective. The assignment and NeoLabs manifest define the boundary. Knowledge of the wider lab does not authorise testing it.

2. The professional testing loop

- 1 **Confirm scope** — target, pod, ports, time window and prohibited actions.
- 2 **Observe** — browse normally and understand the intended workflow.
- 3 **Map** — routes, methods, parameters, object identifiers, roles and services.
- 4 **Form a hypothesis** — only after normal behaviour is understood.
- 5 **Validate safely** — use the minimum action necessary and stay within the proof threshold.
- 6 **Preserve evidence** — request/response, timestamp, target and reproduction steps.
- 7 **Report** — separate observation, risk and recommendation.
- 8 **Retest** — later, after a fix is supplied and retesting is authorised.

Week 1 stops after the mapping/evidence stages. Do not turn a baseline exercise into an exploit hunt.

3. Scope is a security control

Before every live session run:

```
neolabs status
neolabs pod info
neolabs scope
neolabs targets
```

When the toolkit opens an isolated tunnel, the authorised application appears locally at `http://127.0.0.1:18080`. That loopback address represents **your server-assigned pod through your tunnel**. It does not authorise other localhost services or another pod's tunnel listener.

Stop immediately if:

- the manifest shows a different pod or track;
- the target is not the one returned by NeoLabs;
- another pod becomes reachable;
- real data/credentials appear;
- the application becomes unstable.

4. HTTP literacy for testers

For every useful request, be able to explain:

- method (GET, POST, PUT, PATCH, DELETE);
- path/endpoint;
- query parameters and body fields;
- important headers;
- cookies/session indicators;
- response status;
- response data type;
- whether the request reads or changes state.

Common status-code families:

- **2xx** — request completed;
- **3xx** — redirect/state transition;
- **4xx** — client/authentication/authorization/input issue;
- **5xx** — server-side failure.

A status code alone is not a vulnerability. Context matters.

5. Burp Suite Community — safe Week 1 workflow

- 1 Add only the NeoLabs-issued local target to Burp scope.
- 2 Proxy the normal learner workflow.
- 3 Use HTTP history to identify routes, parameters and repeated patterns.
- 4 Send only two normal, non-state-changing requests to Repeater for Week 1.
- 5 Do not enable high-rate automation or extensions that spray requests.
- 6 Redact bearer tokens, cookies and Access Codes before screenshots are submitted.

6. Safe Nmap discovery

Service discovery answers a narrow question: **what student-facing services are exposed on the authorised target?**
Use the toolkit wrapper rather than free-form broad scans.

The Week 1 standard is:

- only the current NeoLabs target;
- low rate;
- no Internet ranges;
- no neighbouring pods;
- no vulnerability scripts;
- no brute force;
- no denial-of-service probes.

Record each observed service with port, protocol, evidence and why it matters to the application map.

7. Application mapping

Build a model before searching for defects. Record:

- major application features;
- learner/admin roles visible from the authorised workflow;
- routes/endpoints;
- methods;
- inputs;
- object identifiers;
- authentication/session boundaries;
- state-changing actions;
- APIs called by the browser;
- observed validation/authorization controls.

A good map lets another tester understand the application's attack surface without repeating your entire browsing session.

8. Evidence quality

For each important observation record:

- event/test time;
- exact authorised target;
- tool/method;
- request or command;
- result;
- evidence reference;
- interpretation;
- limitation.

Do not write “vulnerable” when the evidence only proves “this route exists” or “this control is visible.”

9. Week 1 proof threshold

Allowed: normal browsing, bounded service discovery, safe mapping, non-state-changing Repeater requests, documentation of visible controls.

Not allowed: brute force, credential spraying, authorization bypass attempts, SQL injection/XSS exploitation, destructive input, persistence, automated exploit frameworks, high-rate scanning or denial-of-service.

10. Operation Night Watch checklist

- ☐ Correct pod/track confirmed.
- ☐ Isolated tunnel opened through `neolabs connect`.
- ☐ Only the returned target is in Burp scope.
- ☐ Approved Nmap wrapper used.
- ☐ At least five normal requests documented.
- ☐ Two safe Repeater observations completed.
- ☐ Application Mapping Workbook completed.
- ☐ Service/request map, testing journal and evidence register ready.
- ☐ No exploit or cross-pod testing performed.